HAICHAIN

BÁO CÁO THẨM ĐỊNH RỦI RO THỂ CHẾ V1.1 • TIÊU CHUẨN PHÒNG THỦ MẬT MÃ

HAICHAIN: Báo Cáo Thẩm Định Rủi Ro & Phòng Thủ Mật Mã

Chứng minh Toán học, Mô hình Đe dọa & Ma trận Kiểm thử Xâm nhập Red-Team cho Nhà Đầu tư Thể chế

ĐỐI TƯỢNG BÁO CÁO

Quỹ Mạo Hiểm Hạng 1 & Đơn Vị Kiểm Toán

AN TOÀN MẬT MÃ

Phần Cứng Passkey • Khóa 9 Bất Biến

NHÂN GIAO THỨC

HAICHAIN v1.1 • CapLeaf 223 Bytes

BÁO CÁO THẨM ĐỊNH RỦI RO & PHÒNG THỦ MẬT MÃ HAICHAIN

Chứng minh Toán học, Mô hình Đe dọa & Ma trận Kiểm thử Xâm nhập Red-Team

Đối tượng mục tiêu: Các Quỹ đầu tư mạo hiểm Hạng 1 (a16z crypto, Paradigm, Sequoia), Đơn vị Lưu ký Thể chế và Các Công ty Kiểm toán Bảo mật Hàng đầu (OtterSec, Neodyme, Kudelski Security)
Phiên bản Giao thức: HAICHAIN Kernel v1.1 / CapLeaf v1 (Cấu trúc 223 Bytes Wire Schema)
Tiêu chuẩn: Anchor Framework (Solana L1) + Sui Move (`AgentCap`) + Tron Rail Intent Solver

---

1. TỔNG QUAN ĐIỀU HÀNH & MÔ HÌNH BẢO MẬT

Các AI Agent tự hành thực hiện thanh toán vi mô tạo ra các bề mặt tấn công hoàn toàn khác biệt so với DeFi do con người thao tác: 1. **Độ trễ Không-có-Con-người-can-thiệp:** Một AI Agent khi thực thi các lệnh gọi công cụ có thể bị cưỡng ép thông qua Tấn công Chèn Lệnh Gián tiếp (Indirect Prompt Injection) để phát hành hàng nghìn chứng từ thanh toán trái phép chỉ trong vài giây. 2. **Lỗ hổng Rò rỉ Khóa Bí mật:** Việc chạy các phiên bản agent trên các nút máy chủ phân tán (Cloudflare Workers, máy tính cục bộ MCP, serverless) làm tăng nguy cơ rò rỉ khóa riêng tư. 3. **Sự bùng nổ Tấn công Mạo danh Sybil:** Trong mạng lưới M2M mở, các bên bán độc hại có thể đăng ký vô hạn tên miền rác để vượt qua các hạn chế tỷ lệ giao dịch theo tên miền.

Để giải quyết triệt để bài toán này mà không hy sinh tốc độ mili-giây, **HAICHAIN tách rời hoàn toàn quyền thực thi khỏi quyền lưu ký vốn**: - **Quyền Chủ quyền Tối cao:** Khóa sinh trắc học phần cứng FIDO2 WebAuthn Passkey (P-256) giữ 100% quyền sở hữu bất biến đối với kho quỹ chi tiêu. - **Quyền Hạn của Agent Con:** Các cặp khóa Ed25519 tạm thời (ephemeral) bị cô lập tuyệt đối bên trong Công cụ Chính sách (Policy Engine) ngoài tiến trình, hoàn toàn không có quyền truy cập vào chuỗi hạt giống (seed phrase) của ví gốc. - **Mỏ neo Merkle Trên Chuỗi:** Cấu trúc CapLeaf 223 byte thực thi 9 bất biến toán học bất khả xâm phạm ($I_1 \dots I_9$).

---

2. MÔ HÌNH ĐE DỌA CHÍNH THỨC & CÔNG THỨC GIỚI HẠN THIỆT HẠI

2.1. Phân loại Bề mặt Tấn công

Phân loại Đe dọa	Kịch bản Tấn công	Mức độ Rủi ro Web3 Truyền thống	Giới hạn Thiệt hại Tối đa của HAICHAIN
T_1 (Chèn Lệnh Gián tiếp)	LLM bị lừa trả tiền cho bên bán chưa cấp phép	Cạn kiệt toàn bộ ví (**100.000+**)	**$E_{\text{theft}} = 0$** (Bị chặn bởi Whitelist gốc Merkle)
T_2 (Thông đồng Bên bán)	Bên bán hợp lệ cố gắng rút tiền 2 lần (double-claim)	Bị trừ tiền kép trên tài khoản	$E_{theft} = 0$ (Anchor bắt buộc $P_i \le \min(C_i, R_i)$)
T_3 (Tấn công Miễn Thử việc)	Agent con cố xả tiền liên tục vào API mới	Vét cạn dần số dư kho quỹ	$E_{theft} \le M_{tpl}$ (Khóa theo ngân sách trần mẫu cha)
T_4 (Agent Bị Chiếm Quyền Hoàn Toàn)	Khóa riêng bị lộ + thông đồng với bên bán	Toàn bộ quỹ bị rút sạch ngay lập tức	$E_{theft}(\tau) \le \min(B, K, W_p \cdot n(\tau, \omega_p))$

2.2. Định lý 6.1: Giới hạn Trần Thiệt hại Trường hợp Xấu nhất (T_4)

Gọi τ là tổng thời gian trễ phản hồi của giao thức từ thời điểm một giao dịch trái phép được khởi tạo cho đến khi lệnh ngắt khẩn cấp (Panic Freeze) được ghi nhận thành công trên chuỗi:

$$\tau = t_{detect} + t_{owner} + t_{land}$$

Trong đó: - $t_{detect} \le 5.0s$ (ngưỡng phát hiện dị thường đo lường từ xa) - $t_{owner} \le 2.0s$ (thao tác 1 chạm xác thực sinh trắc học Passkey) - $t_{land} \le 5.0s$ (thời gian đưa giao dịch ưu tiên cao vào khối Solana)

Trong kịch bản xấu nhất khi khóa ký Ed25519 của agent bị lộ hoàn toàn và có sự thông đồng với bên bán đã được xác thực trong cây Merkle, tổng thiệt hại tối đa $E_{theft}(\tau)$ bị chặn cứng bởi công thức:

$$E_{theft}(\tau) \le \min(B,\; K,\; W_p \cdot n(\tau, \omega_p),\; \Sigma_{i:\, m_i \in \mathcal{A}} E_i(\tau))$$

Trong đó: - B: Tổng số dư khả dụng trong kho quỹ (`pot.balance`). - K: Hạn mức chi tiêu tối đa tích lũy của lá phân quyền (`leaf.max_spend`). - W_p: Giới hạn vận tốc tiêu tiền trên mỗi cửa sổ trượt (`leaf.window_cap`). - ω_p: Thời lượng của cửa sổ trượt (mặc định $3.600s$). - $n(\tau, \omega_p) = \lceil \tau / \omega_p \rceil$: Số cửa sổ trượt trải qua trong thời gian phản hồi τ. Với $\tau = 12s \ll 3600s$, $n(\tau, \omega_p) = 1$. - ΣE_i: Tổng hạn mức ký quỹ đang khóa tại các kênh với các bên bán thông đồng.

Hệ quả thực tế: Đối với một kho quỹ thể chế có số dư 10.000 USDT, hạn mức ngân sách lá là 50 USDT, và hạn mức vận tốc là 10 USDT / giờ, kẻ tấn công dù chiếm được khóa của agent cũng **không thể bòn rút quá** 10 USDT trước khi lệnh ngắt khẩn cấp đóng băng toàn bộ quỹ, bảo toàn nguyên vẹn 9.990 USDT **(99,9%)** tài sản.

---

3. MA TRẬN PHÒNG THỦ & KIỂM THỬ XÂM NHẬP RED-TEAM

Trong cuộc kiểm toán điều tra kỹ thuật nội bộ, 5 vector tấn công nghiêm trọng đã được kiểm thử và đóng cứng vào nhân giao thức:

STT	Vector Tấn công	Cơ chế Khai thác Tiềm ẩn	Biện pháp Khắc phục Cốt lõi
1	Rút Tiền Kép Kênh Ký Quỹ (Channel Escrow Double-Dip)	Bên bán gửi nhiều chứng từ tích lũy để rút vượt hạn mức	Thanh toán Đơn điệu Không thể Đảo ngược: <span class="math-in
2	Chiếm Đoạt Tài Khoản ATA	Chuyển hướng thanh toán sang tài khoản Token bên thứ 3	Ràng buộc Khắt khe Địa chỉ ATA Xác thực bất biến PDA trên L1
3	Tấn công Bỏ qua Cầu Dao Khẩn Cấp (Panic-Bypass)	Kênh cũ tiếp tục rút tiền sau khi đã kích hoạt nút Panic	Cách ly Kỷ nguyên Panic Hủy bỏ toàn bộ chứng từ cũ
4	Bòn Rút Lamport Tiền Thuê (Rent Lamport Vampire)	Bên thứ ba chiếm đoạt lamports tiền thuê khi đóng kênh	Hoàn Trả Tuyệt Đối Tiền Thuê Tự động trả về người nạp gốc
5	Tấn công Sybil Vòng lặp Nhỏ	Tạo 1.000 lá thử việc để rút các khoản dự trữ vi mô	Tiêu Hao Ngân Sách Mẫu Cha Khóa cứng trần ngân sách gốc

4. BÁO CÁO KIỂM TOÁN 9 BẤT BIẾN TOÁN HỌC ($I_1 \dots I_9$)

Mọi chỉ thị trên chuỗi trong `programs/haichain-core/src/lib.rs` đều bảo toàn 9 bất biến trạng thái không có ngoại lệ:

1. **I_1 (Bảo toàn Vốn Tối cao):**

> $$Vault_{ATA} + \Sigma_{channels}\ Escrow_j + \Sigma\ Paid_j + Refunds = Tổng\ Tiền\ Nạp\ Ròng$$

Được xác thực bởi kiểm thử `test_invariant_i1_conservation`.

1. **I_2 (An toàn Người Thụ hưởng Đích thực):**

> $$payee_ata \equiv get_associated_token_address(merchant, mint)$$

Thực thi trên chuỗi qua ràng buộc Anchor; triệt tiêu hoàn toàn chuyển hướng tài khoản.

1. **I_3 (Hạn mức Ngân sách Bất biến):**

> $$consumed \le max_spend \quad \wedge \quad budget_used \le budget_total$$

Kiểm tra bắt buộc trước mọi thao tác dự trữ hoặc thanh toán.

1. **I_4 (Giới hạn Tốc độ Tiêu tiền Tự hành):**

> $$window_used \le window_cap \quad \forall\ t \in [T_0,\ T_0 + \omega]$$

Ngăn chặn hành vi rút cạn vốn thần tốc tự động.

1. **I_5 (Thu hẹp Quyền Hạn Đơn điệu PDA):**

> $$Channel\ PDA \subseteq Grant\ PDA \subseteq Pot\ PDA$$

Các thực thể con không bao giờ có thể mở rộng quyền vượt quá thực thể cha.

1. **I_6 (Cách ly Kỷ nguyên Khẩn cấp & Đóng băng Tức thì):**

> $$pot.panic_epoch == channel.created_at_epoch \quad \wedge \quad \neg pot.frozen$$

Đóng băng hệ thống lập tức vô hiệu hóa 100% chứng từ thanh toán đang lưu hành.

1. **I_7 (Hạn Khóa Phiên Làm việc Sinh trắc học):**

> $$current_time \le valid_until$$

Các phiên làm việc hết hạn hoặc bị bỏ rơi không thể thực hiện thêm giao dịch.

1. **I_8 (Thanh toán Đơn điệu & Quyết toán Một lần):**

> $$paid_{new} \le min(cumulative_amount, reserved_amount) \quad \wedge \quad paid_{new} \ge paid_{old}$$

Đảm bảo tuyệt đối không có gian lận chi tiêu kép giữa các chứng từ.

1. I_9 **(Cách ly Tài khoản Chống Tấn công Sybil):**

> PDA("chan", grant, channel_id) là duy nhất

Một lá phân quyền tương ứng chính xác với một tài khoản trên chuỗi duy nhất.

---

5. MÔ HÌNH TOKENOMICS & TUÂN THỦ PHÁP LÝ

5.1. Tiêu chuẩn Tiện ích Thuần túy Không Cổ tức (Miễn nhiễm Howey & MiCA)

- **Không Chia Cổ Tức / Không Staking Thụ Động:** HAICHAIN loại bỏ hoàn toàn mọi hình thức trả lãi thụ động hoặc cam kết lợi nhuận từ công sức của bên thứ ba, đảm bảo tính chất tiện ích thuần túy.
- **50% Phí Mua Lại & Đốt (Buyback & Burn):** 50% doanh thu phí giao thức từ lưu lượng mạng lưới được dùng để mua lại $HAISI trên DEX và đốt vĩnh viễn, tạo áp lực giảm phát gắn liền với mức độ sử dụng thực tế.
- **50% Quỹ Dự trữ Giao thức (CHGB):** 50% phí giao thức được chuyển vào Quỹ dự trữ tự hành có thể bị cắt giảm (slashable reserve) để bảo chứng cam kết chất lượng dịch vụ (SLA) và thanh khoản đa chuỗi.

5.2. Khả năng Quyết toán Đa Chuỗi

- **Solana L1 Anchor Kernel:** Máy trạng thái vi chứng từ gốc với cấu trúc 223 byte, đạt tốc độ chốt giao dịch 400ms.
- **Sui Move Linear Object Model (`AgentCap`):** Cấu trúc phân quyền tuyến tính không có hàm `copy` hay `drop`, ngăn chặn sao chép quyền hạn.
- **Tron TRC20 Rail Solver:** Bộ giải ý định ngoài chuỗi kết hợp bằng chứng kiểm toán Merkle trên chuỗi cho các khoản quyết toán USDT chi phí cực thấp tại các thị trường mới nổi.

---

6. KHUYẾN NGHỊ KIỂM TOÁN NGOÀI & TRUY CẬP PHÒNG DỮ LIỆU DATA ROOM

Gói tài liệu kiểm toán thể chế bao gồm: - `/programs/haichain-core/src/lib.rs` (Anchor Rust Kernel v1.1) - `/programs/haichain-sui/sources/capleaf.move` (Gói Sui Move) - `/sdk/typescript/src/capleaf.ts` (Cấu trúc 223 Byte & Cây Merkle) - `/sdk/typescript/src/policy-engine.ts` (Môi trường Cô lập Khóa Zero-Knowledge) - `/tests/` (72 Kiểm thử Tự động Fuzzing & Xác minh Bất biến đã Passed)

Kết luận: HAICHAIN v1.1 cung cấp lớp thanh toán đầu tiên trên thế giới được chứng minh toán học và cô lập bằng phần cứng cho các AI Agent tự hành, thiết lập tiêu chuẩn vàng về an toàn thể chế trong nền kinh tế AI.